



ESCUELA DE INGENIERÍA Y CIENCIAS

INGENIERÍA EN CIENCIAS DE DATOS Y MATEMÁTICAS

Reporte Ejecutivo

Gestor de Identidades

MA2006B — Uso de Álgebras Modernas para Seguridad y Criptografía

Elaborado por:

Nombre	Matrícula
Ana Laura Reyes Alvarez	A00838315
Nicolás Romero Flota	A01770163
Santiago Pérez Almazán	A01800790
Jose Emilio Gomez Santos	A01665895
Marcelo Sánchez Rodríguez	A01769740
Jesús Emilio Medina García	A00839492

Equipo: 3 | **Grupo:** 604

Profesores:

Daniel Otero | Anas Wajid | Alberto F. Martínez

Socio Formador:

Programa de Atención a Migrantes y sus Familias “Casa Monarca”

Resumen Ejecutivo

El Programa de Atención a Migrantes y sus Familias “Casa Monarca” carecía de un sistema formal para la emisión y validación de documentos institucionales. Los registros se gestionaban de forma manual, sin mecanismos que garantizaran la autenticidad, integridad ni trazabilidad de los documentos, lo que exponía información sensible de personas migrantes a riesgos de alteración, pérdida y acceso no autorizado.

Los objetivos del proyecto fueron: (1) desarrollar un gestor digital de documentos con firma criptográfica verificable; (2) implementar un modelo de control de acceso basado en roles (RBAC) que regule quién puede crear, firmar y revocar documentos; y (3) garantizar que ningún tercero, incluyendo el propio servidor, pueda falsificar una firma digital legítima.

Se desarrolló *Casa Monarca v2*, una plataforma web institucional que integra firma digital con el algoritmo ECDSA sobre la curva P-256 (NIST), generada completamente en el navegador del usuario mediante una frase mnemónica BIP39 de 12 palabras en español. El servidor únicamente almacena la clave pública y verifica las firmas; la clave privada nunca abandona el dispositivo del firmante, eliminando de raíz el riesgo de compromiso desde el servidor.

El resultado es un prototipo funcional con ciclo de vida completo de documentos (*borrador* → *emitido* → *revocado*), verificación pública por folio sin autenticación, bitácora de auditoría completa y despliegue containerizado con Docker Compose. El impacto principal es la reducción del tiempo de registro de 18 a 4 minutos y la eliminación de procesos manuales vulnerables, con garantías matemáticas de autenticidad e integridad basadas en álgebra de curvas elípticas sobre campos finitos.

Objetivos vs Resultados

Qué se cumplió. Se implementaron con éxito todos los objetivos de seguridad criptográfica. El sistema de firma ECDSA P-256 *client-side* opera correctamente: el usuario genera su par de llaves derivando determinísticamente una clave privada de 32 bytes a partir de su mnemónico BIP39, y registra únicamente la clave pública (33 bytes comprimidos) en el servidor. La verificación pública por folio funciona sin autenticación, y el módulo RBAC con cinco roles diferenciados (administrador, supervisor, emisor, verificador, consultor) controla cada operación. La bitácora de auditoría registra IP, *user-agent* y resultado de cada acción. La interfaz web, desplegable en un comando con Docker Compose, fue validada en pruebas de registro, firma y verificación *end-to-end*.

Modificaciones respecto al diseño inicial. El diseño original contemplaba firmas RSA-3072 con la clave privada cifrada (AES-256-CBC + PBKDF2) almacenada en el servidor. Durante el desarrollo se identificó que este modelo implica una custodia de claves en el servidor que, si es comprometido, podría exponer todas las firmas históricas. Se tomó la decisión arquitectónica de migrar a un modelo *client-side* con ECDSA P-256, donde la clave privada se deriva en el navegador y nunca viaja por la red. El flujo de firma se adaptó para usar una tabla *firma_sessions* en base de datos en lugar de `$_SESSION` de PHP, garantizando compatibilidad con entornos multi-contenedor.

Pendientes para versiones futuras. El endpoint de rotación de llaves RSA retorna HTTP 501 (*Not Implemented*). Actualmente no existe *rate limiting* en el endpoint de login; la protección contra fuerza bruta se apoya únicamente en el costo computacional de bcrypt (cost=10, ≈100 ms por verificación). La limpieza periódica de *firma_sessions* debe automatizarse mediante eventos MySQL o *cron job*. El campo *ruta_archivo* en la tabla *documentos* está reservado para adjuntos pero aún no implementado en la lógica de negocio.

Solución Implementada

Qué hace la aplicación. Casa Monarca v2 gestiona el ciclo de vida de documentos institucionales con firma criptográfica auditable. Un usuario con rol *emisor* crea un documento en estado borrador; un firmante diferente (segregación de funciones) introduce su frase mnemónica BIP39 en una cuadrícula de 12 celdas individuales, con la cual el navegador deriva su clave privada ECDSA P-256 y firma el hash SHA-256 del documento. El servidor verifica la firma y transita el documento al estado *emitido*, registrando el folio único en formato DOC-YYYYMMDD-XXXXXX. Cualquier persona puede verificar la autenticidad de un documento accediendo a la URL de verificación con el folio, sin cuenta ni autenticación. El fundamento matemático es la aritmética de puntos en la curva elíptica P-256, definida sobre el campo primo $\mathbb{F}_p$ con $p = 2^{256} - 2^{224} + 2^{192} + 2^{96} - 1$. La firma (r, s) se genera como:

$$r = x_1 \bmod n, \quad s = k^{-1}(e + r d) \bmod n$$

donde d es la clave privada, $e = \text{SHA-256}(m)$, k es un nonce criptográfico aleatorio, n es el orden del grupo, y $(x_1, y_1) = k \cdot G$ con G el punto generador de P-256.

Arquitectura de la solución. El *stack* tecnológico es PHP 8.2 + Apache 2.4 + MySQL 8.0 en el servidor, y HTML5 + ES6 Modules + @noble/curves v1.4.0 en el cliente, orquestado con Docker Compose 3.8. La autenticación usa sesiones PHP con cookies HttpOnly; SameSite=Strict y contraseñas almacenadas como hashes bcrypt irreversibles. Todas las consultas a la base de datos usan PDO con sentencias preparadas, eliminando la posibilidad de inyección SQL.

Usuarios e impacto. El rol *administrador* tiene acceso completo, incluyendo una vista de resumen ejecutivo con historial de movimientos filtrable (emitidos, revocados, firmas fallidas, top firmantes) y panel de gestión de usuarios con cambio de rol. El rol *supervisor* puede firmar y revocar documentos y acceder a la bitácora. El rol *emisor* crea y firma documentos de terceros. Los roles *verificador* y *consultor* tienen acceso de solo lectura.

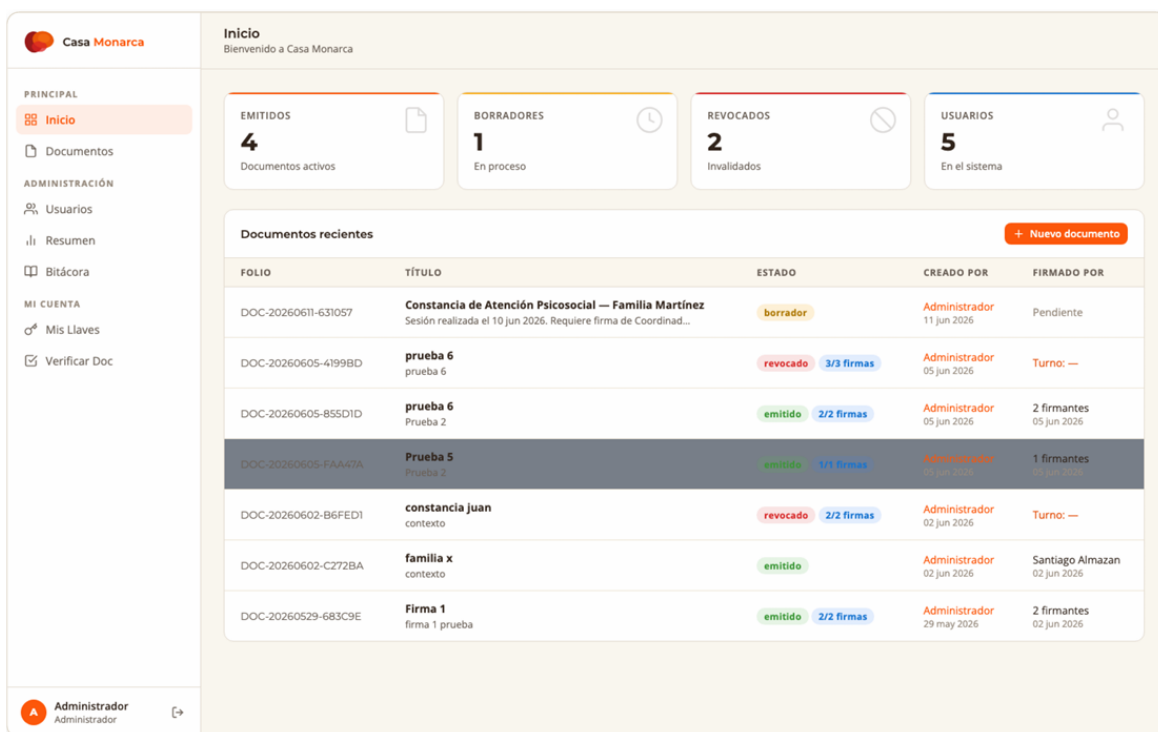


Fig. 1. Vista principal del gestor de documentos: ciclo de vida, creador y firmante por registro.

En la Fig. 1 se observa el panel de documentos del sistema. Cada registro muestra folio único, título, estado del ciclo de vida, usuario creador con fecha, y usuario firmante con fecha de emisión. Los documentos en borrador creados por el usuario activo muestran el indicador “Tu doc” en lugar del botón de firma, implementando la restricción de auto-firma a nivel de interfaz, replicada también en el servidor como segunda capa de defensa.

Impacto

Seguridad de datos. La plataforma elimina la exposición de información sensible de personas migrantes propia de los procesos manuales. Los datos personales que respaldan cada documento nunca circulan en texto plano por la red: la firma se genera íntegramente en el navegador del firmante y el servidor únicamente recibe y almacena la firma (r, s) junto con la clave pública. Un atacante con acceso a la base de datos obtendría exclusivamente hashes bcrypt de contraseñas y claves públicas, sin ningún material que le permita suplantar identidades o retroactivamente forjar documentos.

Derechos ARCO. El sistema habilita el ejercicio efectivo de los derechos de Acceso, Rectificación, Cancelación y Oposición sobre los registros de personas migrantes. El módulo RBAC garantiza que únicamente personal autorizado pueda consultar o modificar datos personales, y la bitácora de auditoría registra de forma inmutable cada operación con IP, *user-agent* y resultado, proporcionando evidencia verificable ante cualquier solicitud ARCO o requerimiento regulatorio.

Autenticidad de documentos. El mecanismo ECDSA P-256 ofrece garantías matemáticas de autenticidad e integridad que ningún proceso basado en firma física puede igualar. Cualquier alteración al contenido de un documento emitido invalida la firma de forma detectable mediante la verificación pública por folio, sin necesidad de contactar al emisor. La separación entre creador y firmante, aplicada tanto en la interfaz como en el servidor, previene conflictos de interés y asegura que cada documento emitido responde a una cadena de custodia verificable. Esto resulta especialmente relevante para la población beneficiaria

de Casa Monarca, cuyos documentos institucionales pueden ser requeridos ante autoridades migratorias como prueba de identidad y atención recibida.

Lecciones y Hallazgos

Qué funcionó bien. La arquitectura de firma *client-side* con ECDSA P-256 y mnemónico BIP39 demostró ser técnicamente sólida y práctica para usuarios no técnicos: las 12 palabras en español son memorables y la derivación determinista permite recuperar las llaves en cualquier momento sin depender del servidor. Reemplazar `$_SESSION` por la tabla `firma_sessions` resolvió elegantemente el problema de sesiones PHP no compartidas en entornos multi-contenedor. El modelo RBAC con cinco roles cubrió todos los casos de uso identificados con Casa Monarca. La cuadrícula de 12 celdas individuales para el ingreso del mnemónico eliminó errores de espaciado y mejoró significativamente la experiencia de firma respecto a un campo de texto libre.

Qué se puede mejorar. El modo legado RSA-3072 usa el `usuario_id` como único factor de derivación PBKDF2 de la clave AES que protege la clave privada almacenada, lo que debilita la protección en reposo frente a un atacante con acceso a la base de datos. En producción, este factor debe combinarse con la contraseña del usuario. La ausencia de *rate limiting* en el endpoint de autenticación expone el sistema a ataques de fuerza bruta automatizados.

Riesgos detectados. El riesgo más significativo en el modelo ECDSA es la pérdida del mnemónico: si un usuario extravía sus 12 palabras, pierde permanentemente el acceso a su clave privada, siendo imposible recuperar o revocar firmas emitidas bajo su identidad criptográfica. Esto exige un protocolo de capacitación riguroso para el personal. Se detectó además que `consulta_qr.php` solo soporta verificación RSA-3072, por lo que los documentos firmados con ECDSA deben verificarse exclusivamente mediante `documentos-verificar.php`.

Estado Actual y Próximos Pasos

Estado: Piloto. El sistema ha sido validado mediante pruebas de firma y verificación *end-to-end*, incluyendo detección de firmas inválidas, rechazo de auto-firma (con excepción para administradores) y verificación pública sin autenticación. El repositorio está disponible en <https://github.com/N1c014s-RF/casa-monarca-v2> y se despliega con `docker compose up --build` en un único comando.

Recomendaciones.

- **Mejoras inmediatas:** Implementar *rate limiting* con ventana deslizante (máximo 10 intentos por IP en 15 minutos) en el endpoint de login. Reforzar la derivación PBKDF2 del modo RSA-3072 combinando `user_id` con la contraseña del usuario. Configurar un evento MySQL o *cron job* para limpieza periódica de `firma_sessions` expiradas. Completar el endpoint `usuarios-rotar-claves.php` (actualmente HTTP 501).
- **Nuevas funcionalidades:** Incorporar sellado de tiempo criptográfico conforme a RFC 3161 para garantizar no repudio temporal de las firmas. Implementar autenticación multifactor (TOTP/WebAuthn) para roles de alta criticidad. Habilitar carga de archivos adjuntos al campo `ruta_archivo`, ya reservado en el esquema de base de datos. Añadir generación de códigos QR por documento para verificación en campo.
- **Escalabilidad:** Migrar la base de datos a un clúster MySQL con replicación geográfica para soportar múltiples sedes de Casa Monarca. Separar el servicio de autenticación en un microservicio compatible con OAuth2/SAML. Desarrollar una aplicación móvil para que los beneficiarios consulten y verifiquen

sus documentos sin acceso a navegador web.

Referencias

- [1] National Institute of Standards and Technology. (2023). *FIPS PUB 186-5: Digital Signature Standard (DSS)*. U.S. Department of Commerce. <https://doi.org/10.6028/NIST.FIPS.186-5>
- [2] Wuille, P., Maxwell, G., et al. (2013). *BIP-0039: Mnemonic code for generating deterministic keys*. Bitcoin Improvement Proposals. <https://github.com/bitcoin/bips/blob/master/bip-0039.mediawiki>
- [3] Barker, E., Chen, L., Roginsky, A., Vassilev, A., & Davis, R. (2019). *NIST Special Publication 800-56B Rev. 2: Recommendation for Pair-Wise Key-Establishment Using Integer Factorization Cryptography*. NIST. <https://doi.org/10.6028/NIST.SP.800-56Br2>
- [4] Ramío Aguirre, J. (2006). *Libro Electrónico de Seguridad Informática y Criptografía* (v. 4.1). Universidad Politécnica de Madrid.
- [5] Shannon, C. E. (1949). Communication theory of secrecy systems. *Bell System Technical Journal*, 28(4), 656–715. <https://doi.org/10.1002/j.1538-7305.1949.tb00928.x>